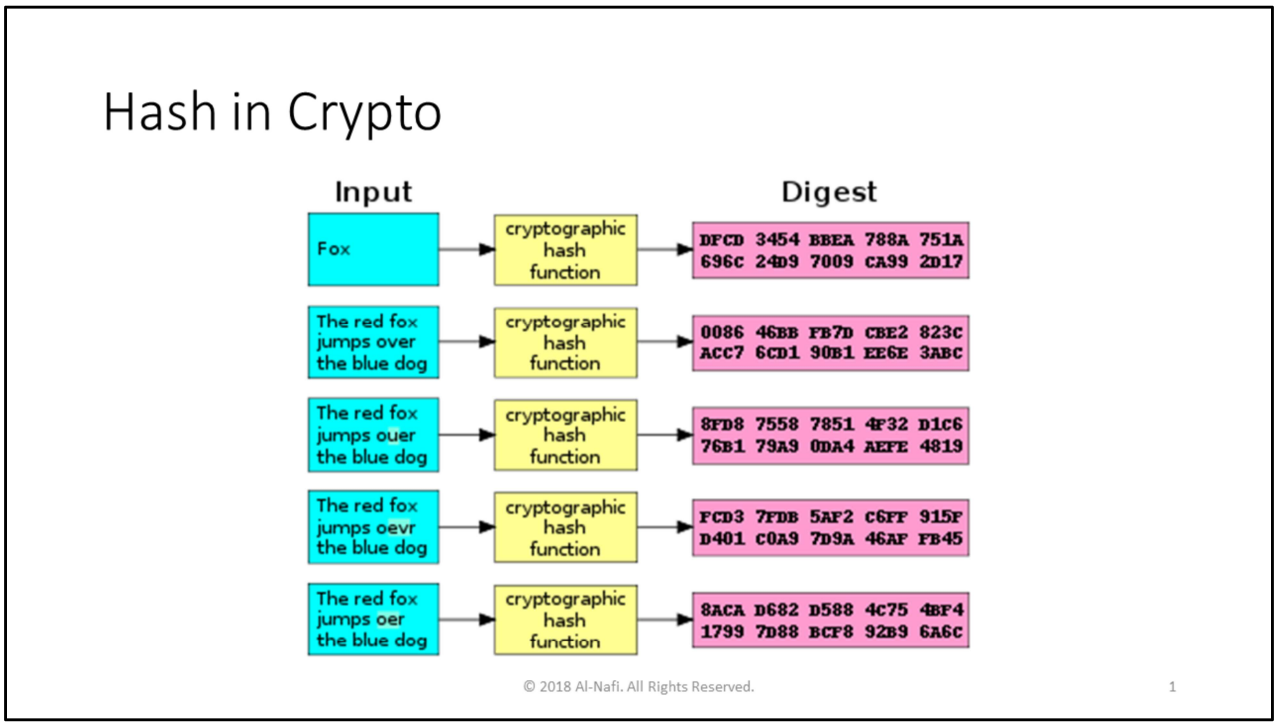
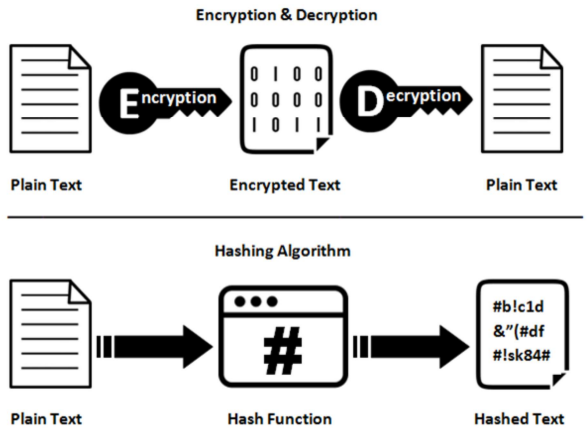


Hash function: A hash function is a one-way mathematical operation that reduces a message or data file into a smaller
fixed length output, or hash value. By comparing the hash value computed by the sender with the hash value computed by the receiver over the original file, unauthorized changes to the file can be detected, assuming they both used the same hash function. Ideally, there should never be more than one unique hash for a given input and one hash exclusively for a given input.

Encryption vs Hashing



Encryption is a two-way function; what is **encrypted** can be decrypted with the proper key. **Hashing**, however, is a one-way function that scrambles plain text to produce a unique message digest. With a properly designed algorithm, there is no way to reverse the **hashing** process to reveal the original password.

© 2018 Al-Nafi. All Rights Reserved.

Reference https://www.securityinnovationeurope.com/blog/page/whats-the-difference-between-hashing-and-encrypting

Hashing and encrypting are two words that are often used interchangeably, but incorrectly so.
Do you understand the difference between the two, and the situations in which you should use one over the other? In today's post I investigate the key differences between hashing and encrypting, and when each one is appropriate.

HASHING - WHAT IS IT?
A hash is a string or number generated from a string of text. The resulting string or number is a fixed length, and will vary widely with small variations in input. The best hashing algorithms are designed so that it's impossible to turn a hash back into its original string.

POPULAR ALGORITHMS
MD5 - MD5 is the most widely known hashing function. It produces a 16-byte hash value, usually expressed as a 32 digit headecimal number. Recently a few

vulnerabilities have been discovered in MD5, and rainbow tables have been published which allow people to reverse MD5 hashes made without good salts.

SHA - There are three different SHA algorithms -- SHA-0, SHA-1, and SHA-2. SHA-0 is very rarely used, as it has contained an error which was fixed with SHA-1. SHA-1 is the most commonly used SHA algorithm, and produces a 20-byte hash value.

SHA-2 consists of a set of 6 hashing algorithms, and is considered the strongest. SHA-256 or above is recommended for situations where security is vital. SHA-256 produces 32-byte hash values.

WHEN SHOULD HASHING BE USED?

Hashing is an ideal way to store passwords, as hashes are inherently one-way in their nature. By storing passwords in hash format, it's very difficult for someone with access to the raw data to reverse it (assuming a strong hashing algorithm and appropriate salt has been used to generate it).

When storing a password, hash it with a salt, and then with any future login attempts, hash the password the user enters and compare it with the stored hash. If the two match up, then it's virtually certain that the user entering the password entered the right one.

Hashing is great for usage in any instance where you want to compare a value with a stored value, but can't store its plain representation for security reasons. Other use cases could be checking the last few digits of a credit card match up with user input or comparing the hash of a file you have with the hash of it stored in a database to make sure that they're both the same.

ENCRYPTION - WHAT IS IT?
Encryption turns data into a series of unreadable characters, that aren't of a fixed length. The key difference between encryption and hashing is that encrypted strings can be reversed back into their original decrypted form if you have the right key.

There are two primary types of encryption, symmetric key encryption and public key encryption. In symmetric key encryption, the key to both encrypt and decrypt is exactly the same. This is what most people think of when they think of encryption.

Public key encryption by comparison has two different keys, one used to encrypt the string (the public key) and one used to decrypt it (the private key). The public key is is made available for anyone to use to encrypt messages, however only the intended

recipient has access to the private key, and therefore the ability to decrypt messages.

POPULAR ALGORITHMS
AES - AES is the "gold standard" when it comes to symmetric key encryption, and is recommended for most use cases, with a key size of 256 bits. Learn more about AES.

PGP - PGP is the most popular public key encryption algorithm.

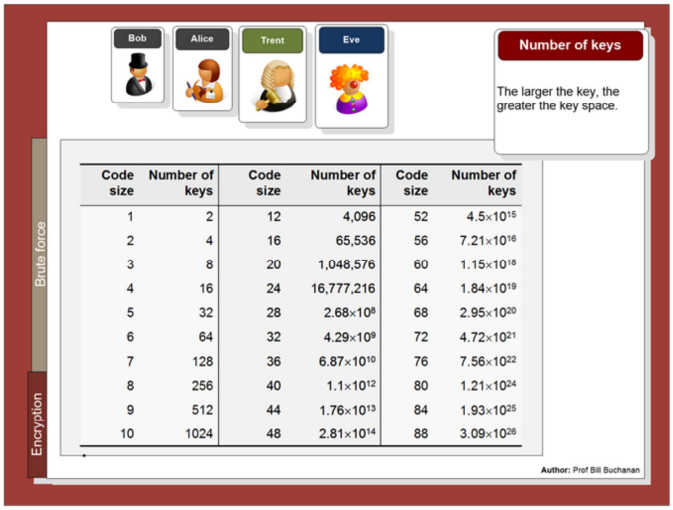
WHEN SHOULD ENCRYPTION BE USED?
Encryption should only ever be used over hashing when it is a necessity to decrypt the resulting message. For example, if you were trying to send secure messages to someone on the other side of the world, you would need to use encryption rather than hashing, as the message is no use to the receiver if they cannot decrypt it. If the raw value doesn't need to be known for the application to work correctly, then hashing should always be used instead, as it is more secure.

If you have a use case where you have determined that encryption is necessary, you then need to choose between symmetric and public key encryption. Symmetric encryption provides improved performance, and is simpler to use, however the key needs to be known by both the person/software/system encrypting and decrypting data.

If you were communicating with someone on the other side of the world, you'd need to find a secure way to send them the key before sharing your secure messages. If you already had a secure way to send someone an encryption key, then it stands to reason you would send your secure messages via that channel too, rather than using symmetric encryption in the first place.

Many people work around this shortcoming of symmetric encryption by initially sharing an encryption key with someone using public key encryption, then symmetric encryption from that point onwards -- eliminating the challenge of sharing the key securely.

Key Space in Cryptography

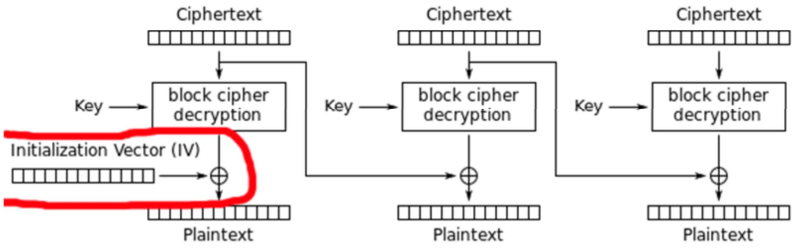


Code size	Number of keys	Code size	Number of keys	Code size	Number of keys
1	2	12	4,096	52	4.5×10^{15}
2	4	16	65,536	56	7.21×10^{16}
3	8	20	1,048,576	60	1.15×10^{18}
4	16	24	16,777,216	64	1.84×10^{19}
5	32	28	2.68×10^{8}	68	2.95×10^{20}
6	64	32	4.29×10^{9}	72	4.72×10^{21}
7	128	36	6.87×10^{10}	76	7.56×10^{22}
8	256	40	1.1×10^{12}	80	1.21×10^{24}
9	512	44	1.76×10^{13}	84	1.93×10^{25}
10	1024	48	2.81×10^{14}	88	3.09×10^{26}

© 2018 Al-Nafi. All Rights Reserved.

Key space: This represents the total number of possible values of keys in a cryptographic algorithm or other security measure, such as a password. For example, a 20-bit key would have a key space of 1,048,576. A 2-bit key would have a key space of 4.

Initialization Vector in Crypto

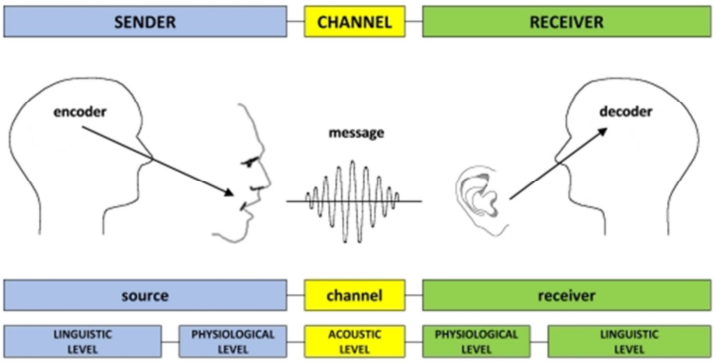


Cipher Block Chaining (CBC) mode decryption

© 2018 Al-Nafi. All Rights Reserved.

Initialization vector (IV): A non-secret binary vector used as the initializing input algorithm for the encryption of a plaintext
block sequence to increase security by introducing additional cryptographic variance and to synchronize cryptographic
equipment. Typically referred to as a “random starting point,” or random number that starts the process.

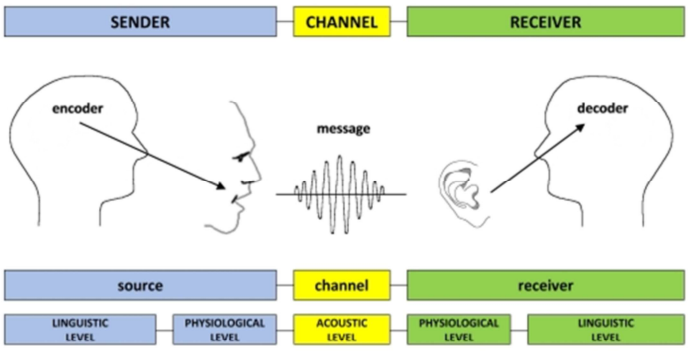
Encoding in Crypto



© 2018 Al-Nafi. All Rights Reserved.

Encoding: The action of changing a message into another format through the use of a code. This is often done by taking
a plaintext message and converting it into a format that can be transmitted via radio or some other medium, and it is usually used for message integrity instead of secrecy. An example would be to convert a message to Morse code.

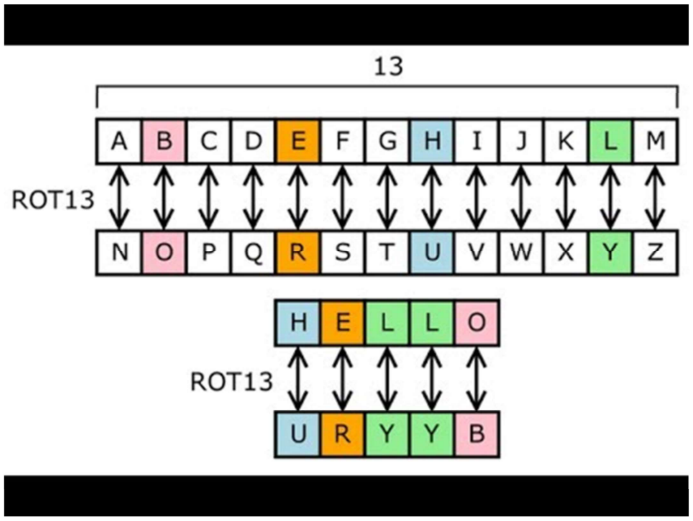
Decoding in Crypto



© 2018 Al-Nafi. All Rights Reserved.

Decoding: The reverse process from encoding, converting the encoded message back into its plaintext format.

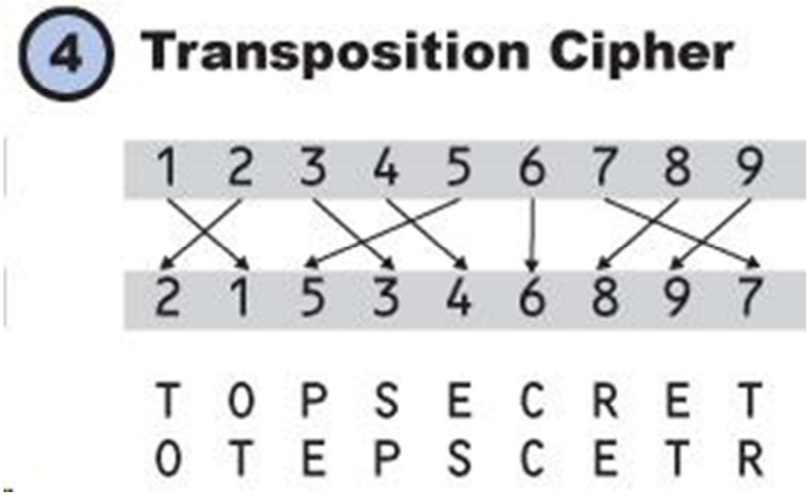
Substitution in Cryptography



© 2018 Al-Nafi. All Rights Reserved.

Substitution: The process of exchanging one letter or byte for another. An example is the Caesar cipher, where each letter was shifted by 3 characters. An “A” was represented by a “D,” a “B” was represented by an “E,” a “C” was represented by an “F,” and so on.

Transposition in Cryptography



© 2018 Al-Nafi. All Rights Reserved.

Transposition or permutation: The process of reordering the plaintext to hide the message, but keeping the same letters.